

NIST CSF 2.0

Step 5 — Gap Calculation & Prioritization

Industry-Style Cybersecurity Gap Assessment | Current vs Target Organizational Profile

Organization	LearnSphere EdTech
Assessment Scope	Cloud-hosted LMS, AWS infrastructure, applications, databases, IAM, source code, CI/CD, backups, monitoring, endpoints and relevant third parties.
Assessment Focus	Children's data governance, parental-consent and data-minimization practices, and access controls for student records.
Framework	NIST Cybersecurity Framework (CSF) 2.0
Assessment Method	Internal 0–4 maturity scoring mapped to Current and Target Profiles; gap = Target – Current.
Document Status	Draft for portfolio / management review

Management objective: identify the largest maturity gaps first, connect each gap to a practical remediation action, and provide a sequenced basis for the Step 6 remediation roadmap.

1. Purpose and Assessment Method

This step converts the Current and Target Profile ratings established in the NIST CSF 2.0 assessment into a quantified gap view. The objective is not to produce a pass/fail compliance result. Instead, the analysis highlights where LearnSphere's existing, partly ad hoc security practices are furthest from the defined target state and therefore require management attention.

Gap formula: Gap = Target Maturity – Current Maturity.

A positive gap represents maturity improvement required. A gap of 0 indicates that the current rating already meets the defined target. For this assessment, the internal 0–4 scale is used consistently across all six NIST CSF Functions; it is a project scoring method and should not be confused with NIST's official CSF Tier terminology.

Score	Internal interpretation	Assessment meaning
0	Not Performed	Outcome is not performed or there is no credible evidence.
1	Ad Hoc	Inconsistent, informal or reactive practice.
2	Repeatable	Performed with some consistency but documentation, coverage or measurement is incomplete.
3	Defined	Formally documented, assigned and consistently implemented/integrated.
4	Managed / Optimized	Measured, reviewed for effectiveness and continuously improved.

2. Executive Gap Summary

Function	Current	Target	Gap	Priority
Govern	1.75	3.00	1.25	High
Identify	1.75	3.00	1.25	High
Protect	1.75	3.25	1.50	Critical
Detect	1.75	3.00	1.25	High
Respond	2.00	3.00	1.00	Medium-High
Recover	1.75	3.00	1.25	Medium
Overall	1.79	3.04	1.25	Critical / High focus

The largest functional gap is Protect at 1.50, driven principally by student-record access governance. Governance, Identify and Detect each show a 1.25 gap. Respond is comparatively stronger at 1.00, while Recover remains at 1.25 because recovery testing and improvement processes are not yet consistently institutionalized.

3. Prioritized Gap Register — Largest Gaps First

The register below is deliberately sorted by gap magnitude and then by risk priority. Gaps of 2 points represent the greatest maturity movement in this assessment and are placed first. Within the same gap band, Critical and High priorities receive earlier management attention.

Rank	Gap ID	NIST Outcome	Function	Current	Target	Gap	Priority	Timing
1	GAP-09	PR.AA-05	Protect	2	4	2	Critical	0–90 days
2	GAP-01	GV.OC-03	Govern	1	3	2	High	Immediate
3	GAP-06	ID.AM-07	Identify	1	3	2	High	0–90 days
4	GAP-12	PR.DS-10	Protect	1	3	2	High	0–90 days
5	GAP-16	DE.AE-04	Detect	1	3	2	High	31–90 days
6	GAP-24	RC.IM-01	Recover	1	3	2	Medium	91–180 days
7	GAP-02	GV.RM-01	Govern	2	3	1	High	30–90 days
8	GAP-03	GV.RR-02	Govern	2	3	1	High	0–30 days
9	GAP-04	GV.PO-01	Govern	2	3	1	High	30–90 days
10	GAP-05	ID.AM-02	Identify	2	3	1	High	31–90 days
11	GAP-07	ID.RA-04	Identify	2	3	1	High	31–90 days
12	GAP-08	ID.RA-05	Identify	2	3	1	High	0–90 days
13	GAP-10	PR.AA-03	Protect	2	3	1	High	31–90 days
14	GAP-11	PR.DS-01	Protect	2	3	1	High	31–90 days
15	GAP-13	DE.CM-01	Detect	2	3	1	High	31–90 days
16	GAP-14	DE.CM-06	Detect	2	3	1	High	91–180 days
17	GAP-15	DE.AE-02	Detect	2	3	1	High	31–90 days
18	GAP-17	RS.MA-01	Respond	2	3	1	Medium-High	31–90 days
19	GAP-18	RS.AN-03	Respond	2	3	1	Medium-High	31–90 days
20	GAP-19	RS.CO-02	Respond	2	3	1	Medium-High	31–90 days
21	GAP-20	RS.MI-01	Respond	2	3	1	Medium-High	31–90 days
22	GAP-21	RC.RP-01	Recover	2	3	1	Medium	91–180 days
23	GAP-22	RC.RP-03	Recover	2	3	1	Medium	91–180 days
24	GAP-23	RC.CO-02	Recover	2	3	1	Medium	91–180 days

Management interpretation: The two-point gaps are not simply “low scores.” They identify outcomes that require a structured maturity uplift from an ad hoc state to a defined operating model. These should be treated as leading remediation candidates because they also affect privacy, access, accountability and lifecycle risk.

4.1 Govern — Detailed Gap Analysis

Function position: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High. The following outcomes explain the specific maturity movement required within Govern.

GAP-01 GV.OC-03	Current: 1	Target: 3	Gap: 2	High
--------------------------	------------	-----------	--------	------

Current-state finding: Legal, regulatory, contractual and privacy requirements are not consistently translated into documented operational requirements for children's data.

Target-state requirement: Establish a requirements register covering privacy, children's-data obligations, parental-consent expectations, contractual commitments and civil-liberties considerations; assign owners and map requirements to policies, processes and evidence.

Expected evidence at target: Approved requirements register; legal/privacy review records; control or process mappings; assigned owners; periodic review evidence.

Recommended timing: Immediate

GAP-02 GV.RM-01	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Cybersecurity risk assessment is performed, but it is not consistently embedded into product changes and new or changed student-data processing activities.

Target-state requirement: Make cybersecurity and privacy risk assessment a defined input to product, architecture, data-processing and significant change workflows, with risk acceptance and treatment decisions recorded.

Expected evidence at target: Change workflow; risk assessment template; completed assessments; risk acceptance records; sample product-change evidence.

Recommended timing: 30–90 days

GAP-03 GV.RR-02	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Accountability for children's-data governance is not consistently formalized across security, product, engineering and business stakeholders.

Target-state requirement: Define accountable and responsible roles for children's-data governance, consent, minimization, access, retention and incident escalation through a documented RACI.

Expected evidence at target: Approved RACI; role descriptions; committee/meeting records; assigned action owners.

Recommended timing: 0–30 days

GAP-04 GV.PO-01	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Existing policies provide a baseline but do not consistently translate children's-data protection into collection, consent, minimization, access and retention requirements.

Target-state requirement: Update relevant policies and standards so that children's-data handling requirements are explicit, operational and traceable to business processes.

Expected evidence at target: Approved policies; standards; policy-to-process mapping; communication/acknowledgement evidence.

Recommended timing: 30–90 days

4.2 Identify — Detailed Gap Analysis

Function position: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High. The following outcomes explain the specific maturity movement required within Identify.

GAP-05 ID.AM-02	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Software, services and supporting technology are not consistently linked to the types of student information they process or support.

Target-state requirement: Create an application/service inventory with ownership, business purpose, data types, environments, integrations and criticality.

Expected evidence at target: CMDB/application inventory; data-flow mapping; service owners; criticality classification; review evidence.

Recommended timing: 31–90 days

GAP-06 ID.AM-07	Current: 1	Target: 3	Gap: 2	High
--------------------------	------------	-----------	--------	------

Current-state finding: The inventory of designated/sensitive student data and associated metadata is incomplete, limiting visibility into where children's data resides and how it is used.

Target-state requirement: Maintain an authoritative inventory of designated data types and relevant metadata, including system location, owner, purpose, sensitivity and retention requirements.

Expected evidence at target: Data inventory; metadata fields; data owner register; data-flow diagrams; periodic reconciliation evidence.

Recommended timing: 0–90 days

GAP-07 ID.RA-04	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Changes to student-data processing do not consistently trigger a structured cybersecurity risk assessment.

Target-state requirement: Integrate risk assessment triggers into change management, product development and data-processing change procedures.

Expected evidence at target: Workflow gates; change tickets; completed risk assessments; exception records.

Recommended timing: 31–90 days

GAP-08 ID.RA-05	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Data-minimization risk is not consistently assessed as a distinct factor when collecting, storing or introducing new student information.

Target-state requirement: Add data minimization and purpose limitation to risk assessment criteria and require documented justification for new data elements.

Expected evidence at target: Risk assessment criteria; data-field review; collection justification; exception approvals.

Recommended timing: 0–90 days

4.3 Protect — Detailed Gap Analysis

Function position: Current 1.75 | Target 3.25 | Gap 1.50 | Priority Critical. The following outcomes explain the specific maturity movement required within Protect.

GAP-09 | PR.AA-05

Current: 2

Target: 4

Gap: 2

Critical

Current-state finding: Access permissions and entitlements are not consistently subject to evidence-based review, creating elevated risk for unauthorized access to student records.

Target-state requirement: Implement formal RBAC, least privilege, separation of duties, recurring access certification, privileged-access governance and exception management for student records.

Expected evidence at target: RBAC matrix; quarterly access certifications; privileged-account register; JML evidence; access exceptions; review metrics.

Recommended timing: 0–90 days

GAP-10 | PR.AA-03

Current: 2

Target: 3

Gap: 1

High

Current-state finding: Authentication requirements vary by system and access path and are not consistently risk-based for sensitive student-data access.

Target-state requirement: Define risk-based authentication requirements, including MFA for privileged and sensitive access, and document exceptions.

Expected evidence at target: Authentication standard; MFA coverage report; privileged-access evidence; exception register.

Recommended timing: 31–90 days

GAP-11 | PR.DS-01

Current: 2

Target: 3

Gap: 1

High

Current-state finding: Protection of student information is not consistently mapped across databases, backups, exports, logs and third-party processing.

Target-state requirement: Define data-protection requirements across the information lifecycle and map safeguards to each storage, transfer and processing location.

Expected evidence at target: Data-protection standard; encryption/key-management evidence; data-flow controls; backup/export safeguards; supplier requirements.

Recommended timing: 31–90 days

GAP-12 | PR.DS-10

Current: 1

Target: 3

Gap: 2

High

Current-state finding: Retention and disposal practices are not consistently enforced across systems containing student information.

Target-state requirement: Establish retention schedules, disposal mechanisms, exception handling and verification for student records and associated copies.

Expected evidence at target: Retention schedule; deletion jobs; disposal logs; exception register; sample verification records.

Recommended timing: 0–90 days

Critical management emphasis: PR.AA-05 is intentionally targeted at Level 4 rather than Level 3. Student records are a high-sensitivity information set, and the target therefore requires not only documented access governance but measurable, recurring review, privileged-access oversight, exception tracking and evidence that the control model is improving over time.

4.4 Detect — Detailed Gap Analysis

Function position: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High. The following outcomes explain the specific maturity movement required within Detect.

GAP-13 DE.CM-01	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Monitoring exists, but coverage of critical assets and student-data environments is not consistently measured against defined objectives.

Target-state requirement: Define monitoring coverage requirements and KPIs for critical infrastructure, applications, IAM and student-data access paths.

Expected evidence at target: Monitoring coverage matrix; SIEM source inventory; KPI dashboard; periodic coverage review.

Recommended timing: 31–90 days

GAP-14 DE.CM-06	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Monitoring expectations for relevant third parties are inconsistent and are not uniformly tied to supplier risk.

Target-state requirement: Define security monitoring and notification expectations for critical suppliers and integrate them into supplier assurance.

Expected evidence at target: Supplier monitoring clauses; assurance reviews; incident notification requirements; evidence of monitoring coverage.

Recommended timing: 91–180 days

GAP-15 DE.AE-02	Current: 2	Target: 3	Gap: 1	High
--------------------------	------------	-----------	--------	------

Current-state finding: Alert investigation is performed, but investigation quality and timeliness are not consistently measured using defined metrics.

Target-state requirement: Standardize alert triage and investigation with MTTD/MTTI-style measures, investigation quality criteria and management reporting.

Expected evidence at target: Incident/alert workflow; investigation records; MTTD/MTTI metrics; monthly reporting; quality review.

Recommended timing: 31–90 days

GAP-16 DE.AE-04	Current: 1	Target: 3	Gap: 2	High
--------------------------	------------	-----------	--------	------

Current-state finding: Correlation between IAM events, application activity and access to student records is not consistently defined, reducing detection capability for misuse.

Target-state requirement: Develop correlation rules and use cases for anomalous student-record access, privileged activity and identity/application events.

Expected evidence at target: SIEM correlation rules; use-case catalogue; test alerts; investigation records; tuning history.

Recommended timing: 31–90 days

4.5 Respond — Detailed Gap Analysis

Function position: Current 2.00 | Target 3.00 | Gap 1.00 | Priority Medium-High. The following outcomes explain the specific maturity movement required within Respond.

GAP-17 | RS.MA-01

Current: 2

Target: 3

Gap: 1

Medium-High

Current-state finding: Incident categorization does not consistently distinguish the severity and impact of incidents involving children's data.

Target-state requirement: Define severity criteria that explicitly consider children's data, volume, sensitivity, unauthorized disclosure and regulatory/customer impact.

Expected evidence at target: Incident severity matrix; classification examples; incident tickets; escalation records.

Recommended timing: 31–90 days

GAP-18 | RS.AN-03

Current: 2

Target: 3

Gap: 1

Medium-High

Current-state finding: Evidence collection and analysis for unauthorized access to student records is not fully standardized.

Target-state requirement: Create evidence-preservation and analysis procedures covering IAM logs, application logs, database activity and relevant endpoint evidence.

Expected evidence at target: Forensic/evidence procedure; chain-of-custody records; sample incident packages; investigation checklist.

Recommended timing: 31–90 days

GAP-19 | RS.CO-02

Current: 2

Target: 3

Gap: 1

Medium-High

Current-state finding: Communication and escalation roles for student-data incidents are not consistently defined across technical, legal/privacy and management stakeholders.

Target-state requirement: Define incident communications RACI, escalation thresholds, decision rights and notification dependencies.

Expected evidence at target: Incident communications plan; RACI; escalation matrix; exercise records.

Recommended timing: 31–90 days

GAP-20 | RS.MI-01

Current: 2

Target: 3

Gap: 1

Medium-High

Current-state finding: Predefined response playbooks for compromised student records are incomplete.

Target-state requirement: Develop and exercise playbooks for unauthorized access, data exposure, credential compromise, ransomware and accidental disclosure affecting student information.

Expected evidence at target: Approved playbooks; tabletop records; action logs; post-exercise improvements.

Recommended timing: 31–90 days

4.6 Recover — Detailed Gap Analysis

Function position: Current 1.75 | Target 3.00 | Gap 1.25 | Priority Medium. The following outcomes explain the specific maturity movement required within Recover.

GAP-21 | RC.RP-01

Current: 2

Target: 3

Gap: 1

Medium

Current-state finding: Recovery testing is not consistently scenario-based for ransomware, database compromise or student-data loss.

Target-state requirement: Conduct scenario-based recovery exercises covering critical LMS services, databases, backups and student-data integrity.

Expected evidence at target: Recovery test plans; exercise results; RTO/RPO evidence; restoration logs; corrective actions.

Recommended timing: 91–180 days

GAP-22 | RC.RP-03

Current: 2

Target: 3

Gap: 1

Medium

Current-state finding: Recovery priorities and dependencies are not consistently documented against agreed RTO/RPO requirements.

Target-state requirement: Document service dependencies, recovery sequence, RTO/RPO and business priorities for critical student-facing services.

Expected evidence at target: BIA/recovery matrix; dependency maps; approved RTO/RPO; recovery runbooks.

Recommended timing: 91–180 days

GAP-23 | RC.CO-02

Current: 2

Target: 3

Gap: 1

Medium

Current-state finding: Communication requirements for service disruption and recovery are not consistently defined for student-facing incidents.

Target-state requirement: Define recovery communications for school customers, administrators, internal stakeholders and relevant suppliers.

Expected evidence at target: Recovery communications plan; templates; contact lists; exercise evidence.

Recommended timing: 91–180 days

GAP-24 | RC.IM-01

Current: 1

Target: 3

Gap: 2

Medium

Current-state finding: Lessons learned are not systematically converted into tracked, owned and verified improvements.

Target-state requirement: Establish a post-incident and post-exercise improvement process with owners, due dates, risk linkage and closure verification.

Expected evidence at target: Lessons-learned records; corrective-action tracker; ownership/dates; closure evidence; management review.

Recommended timing: 91–180 days

5. Cross-Functional Gap Themes and Root Causes

Although the register contains 24 individual outcomes, the gaps cluster into a smaller number of systemic themes. Treating these themes as management workstreams avoids implementing 24 disconnected actions.

Theme	NIST outcomes	Underlying issue	Management response
T1 — Children's-data governance	GV.OC-03, GV.RR-02, GV.PO-01	Unclear ownership, incomplete operational translation of privacy requirements and inconsistent policy integration.	Governance owner/RACI, requirements register, policy updates and review cadence.
T2 — Data visibility and minimization	ID.AM-02, ID.AM-07, ID.RA-04, ID.RA-05, PR.DS-10	Incomplete inventory and inconsistent linkage between data collection, purpose, risk and retention.	Authoritative data inventory, data-flow mapping, minimization assessment and retention schedule.
T3 — Student-record access governance	PR.AA-05, PR.AA-03	Access governance is not sufficiently consistent, evidence-based and risk differentiated.	RBAC, least privilege, SoD, MFA, quarterly certification, privileged access and exceptions.
T4 — Monitoring and detection engineering	DE.CM-01, DE.CM-06, DE.AE-02, DE.AE-04	Coverage and correlation are not consistently defined or measured.	Monitoring coverage matrix, third-party expectations, investigation KPIs and correlation use cases.
T5 — Children's-data incident response	RS.MA-01, RS.AN-03, RS.CO-02, RS.MI-01	Incident handling does not consistently incorporate children's-data impact and evidence requirements.	Severity model, evidence procedure, communications RACI and tested playbooks.
T6 — Recovery and continual improvement	RC.RP-01, RC.RP-03, RC.CO-02, RC.IM-01	Recovery dependencies, exercises and lessons-learned closure are not fully institutionalized.	Scenario exercises, recovery dependency mapping, communications plan and corrective-action tracking.

The most important cross-functional dependency is the relationship between Governance and Identify. LearnSphere cannot reliably enforce minimization, retention or access requirements if it cannot first identify what student data exists, why it is processed, where it resides and who owns it.

6. Management Prioritization Logic

The gap score is the primary sorting mechanism requested for Step 5. Risk sensitivity and implementation dependency are then used to make the result operationally useful. This prevents a narrow numerical ranking from hiding a high-impact security issue such as student-record access governance.

Factor	How it is used
Gap magnitude	2-point gaps are surfaced before 1-point gaps because they represent the greatest maturity movement.
Risk sensitivity	Children's data and student records receive higher attention because compromise can create significant privacy, trust and regulatory impact.
Dependency	Foundational inventory and governance activities are accelerated where they enable downstream controls such as access, retention and detection.
Feasibility	Targets are generally one maturity level above current state; the exception is PR.AA-05, targeted at Level 4 because of student-record sensitivity.
Evidence	Each gap includes expected evidence so remediation can later be verified through assessment, audit or management review.

7. Step 5 Management Conclusion

LearnSphere's overall Current Profile score is 1.79/4 against a Target Profile of 3.04/4, producing an overall maturity gap of 1.25 points. The largest function-level gap is Protect at 1.50. The principal risk driver is access governance over student records, represented by PR.AA-05 with a 2-point gap and a Critical priority.

The assessment also shows that several gaps are foundational rather than isolated technical weaknesses. Children's-data requirements, ownership, data inventory and minimization must be strengthened before the organization can demonstrate consistent lifecycle protection and risk-informed access decisions. Detect, Respond and Recover improvements should therefore be implemented as connected workstreams rather than independent technical projects.

Step 5 output should be used as the direct input to Step 6: a prioritized remediation roadmap with accountable owners, target dates, dependencies, measurable acceptance criteria and closure evidence.

8. Step 6 Input — Remediation Roadmap Priorities

The following sequence translates the Step 5 ranking into a practical implementation order. It is intentionally phased so LearnSphere can establish governance and visibility before expanding measurement and optimization.

Phase	Workstream	Priority actions	Primary gaps
0–30 Days	GOVERN & CONTAIN	Children's-data governance owner/RACI; requirements register; parental-consent requirements; emergency student-record access review; privileged-account review; identify excessive data collection; define immediate risk-assessment triggers.	GAP-01, 03, 06, 08, 09, 12
31–90 Days	DEFINE & IMPLEMENT	Formal data inventory; application-to-data mapping; minimization assessment; quarterly access certification; RBAC/SoD; authentication requirements; retention/disposal controls; monitoring KPIs; student-data incident playbook; detection correlation use cases.	GAP-02, 04–05, 07, 09–11, 13, 15–20
91–180 Days	TEST, MEASURE & IMPROVE	Recovery exercises; RTO/RPO dependency validation; third-party monitoring expectations; security metrics; lessons-learned process; management review; reassess Current Profile against Target Profile.	GAP-14, 21–24 + validation of prior gaps

Acceptance principle: a gap should not be marked closed merely because a policy or procedure was issued. Closure should require evidence that the target outcome is operating consistently, is assigned to an owner, and—where appropriate—is measured or reviewed for effectiveness.

9. Approval and Governance

Prepared By	Mr. Meejan Shaikh – GRC Analyst	Signature: _____	Date: 04-Sep-2026
Reviewed By	Information Security Manager	Signature: _____	Date: 04-Sep-2026
Approved By	CISO	Signature: _____	Date: 04-Sep-2026

Document control: LS-NIST-001 | Version 1.0 | NIST CSF 2.0 Project 2 — Step 5 | Internal / Confidential